

Halden Distribution Ltd. — privileged access standard

Document type: IT security standard · **Owner:** IT (Systems) · **Approver:** Managing Director **Version:** 1.0 (designed) · **Date:** 2026-10-02 · **Review:** quarterly, and after any privileged access incident · **Applies to:** every account, group and device in `ad.halden.internal`

Purpose: to say, in one place, how administrative access at Halden is granted, used, monitored and withdrawn, so that "who can change the domain?" has a written answer and a test that proves it.

1. The one rule

No person uses an account with administrative rights for everyday work.

Every member of IT holds an **ordinary account** for email, browsing and documents, and a ****separate administrator account**** for each tier they are responsible for. Admin accounts are never used to read email or browse the web, because that is how a domain administrator's credential ends up on a machine an attacker already controls.

2. The tier model

Tier	What it covers	Admin account pattern	May log on to	Why the boundary exists
Tier 0	Domain controllers, Active Directory, Entra Connect, the certificate authority, domain controller backups	<code>adm-t0- <name></code>	Domain controllers and the privileged access workstation only	A Tier 0 compromise is a domain compromise
Tier 1	Member servers and the applications on them	<code>adm-t1- <name></code>	Member servers only	Server administration must not carry rights over workstations
Tier 2	Workstations and user support	<code>adm-t2- <name></code>	Workstations only	The helpdesk's real job is a password reset or an unlock, which delegation grants without elevated rights

Accounts, groups and the privileged access workstation live in the `_Admin` OU tree (`Tier0|Tier1|Tier2\Accounts|Groups` , `PAW\Devices`). The machine-readable version is `configs/p03-tiering-model.csv` ; the source of the proposed accounts is the synthetic `data/halden-account-inventory.csv` .

3. Rules for administrator accounts

#	Rule	Rationale
1	One admin account per person per tier. Never share; never a "team" admin account	Shared accounts destroy accountability
2	Admin accounts carry no mailbox and are not used for browsing	Stops credentials landing on a low-trust machine

#	Rule	Rationale
3	Each admin account is marked " sensitive and cannot be delegated "	Prevents credential theft through delegation
4	Human Tier 0 accounts are members of Protected Users (no NTLM, no delegation, no cached credentials, short-lived tickets)	Removes whole attack techniques. Service and computer accounts must never be added
5	Elevated rights are granted through groups, never directly to an account	Reviews stay readable; removing access is one edit
6	Admin passwords follow the stricter policy: minimum 20 characters, lockout after 5 attempts, maximum age 180 days	Justified by the impact of the account, not a blanket rule
7	Break-glass: the built-in Administrator is the only exception to the deny-logon rules. Its password is stored offline in the owner's password manager and is reviewed at every quarterly review	An account nobody uses is the one that still works when everything else is locked
8	Permanent domain administrator rights are not required for any routine task. Password resets and unlocks are delegated to the helpdesk on user organisational units only	Removes the everyday need for the highest rights

4. Local administrator passwords (Windows LAPS)

- Every workstation and member server has a **unique local administrator password**, managed by Windows LAPS, backed up to Active Directory and **encrypted**.
- Passwords are **20 characters**, complexity on, and **rotate every 30 days** (or sooner with the expiration-protection setting).
- After a password is retrieved, the endpoint **resets it and signs the session off after 8 hours**.
- **Who may read a password:**

Scope	May read	Members of that group are reviewed
Workstations	G_Tier2_Helpdesk	Monthly
Member servers	G_Tier1_ServerAdmins	Monthly
Domain controllers (including the DSRM password)	G_Tier0_Admins	Monthly

- **A retrieved LAPS password is a credential.** It is never written into a ticket, an email, a chat message or a screenshot. A published or pasted LAPS password is treated as a leaked credential.

5. Service accounts

- New service identities use **group Managed Service Accounts (gMSA)** with an automatically rotated machine-managed password. A gMSA has no password for anyone to know.
- Existing service accounts are migrated to a gMSA in turn, and the legacy account is disabled once

the service runs on the gMSA. Verification: the service account test must succeed before the old account is disabled (for example `Test-ADServiceAccount gmsa-sql`).

- Where a gMSA genuinely cannot be used, the account is documented with a reason, its password is a minimum of 25 characters, it is owned by a named person, and it appears in the privileged access review.
- Service accounts are **never** added to Protected Users and never granted interactive logon rights.

6. Devices

- The **privileged access workstation (PAW)** — WS02 in this build — is the only device from which Tier 0 administration is performed. Only Tier 0 accounts may sign in to it, and it is kept off the general user network once the P6 firewall work is complete.
- Admin accounts are subject to **deny-logon rules**: Tier 0 and Tier 1 administrators cannot sign in to workstations; Tier 0 and Tier 2 administrators cannot sign in to member servers; only Tier 0 administrators can sign in to a domain controller.

7. Monitoring and review

Activity	Frequency	Evidence
Automated privileged access and control verification	Monthly	<code>scripts/12-Invoke-PrivilegedAccessReview.sh</code> output
Human review of exceptions, and sign-off of people who can read LAPS passwords	Quarterly	This document's review section, and the register
Register review: open items, accepted risks, due dates	Monthly	<code>p03-findings-register.md</code>
Break-glass account password rotation	Quarterly, and after any use	Password manager entry and the review log

An exception is either **fixed** or **risk-accepted** with a named business owner, a written reason and a review date. It is never closed silently.

8. Review log

Date	Reviewed by	Open items	Accepted risks (owner, review date)	Next review

Status: standard issued as a design and not yet applied. Halden Distribution Ltd. is a fictional company in an isolated home lab; the standard is real, the company is not. The approver line above is unsigned until the owner signs it, and the review log is empty because no review has happened yet.

